



2 DE SEPTIEMBRE DE 2026

Análisis y Planificación del Pentest

ESECENARIO: AURORA MARKET

LOURDES MENDIETA
HACKER WOMEN COUNCIL • ETHICAL HACKING
Asunción, Paraguay

Contenido

1. OBJETIVO DEL PENTEST	2
2. ALCANCE.....	2
➤ SÍ SE EVALUARÁ:.....	2
➤ FUERA DEL ALCANCE:.....	2
3. AUTORIZACIÓN Y CONDICIONES	2
➤ PERMISOS REQUERIDOS:.....	2
➤ CONDICIONES ACORDADAS:.....	2
4. TIPO DE PENTEST	3
5. PLANIFICACIÓN	3
6. FASES DEL PENTEST	3
7. INVESTIGACIÓN	4

1. OBJETIVO DEL PENTEST

1. **Identificar y comprender los riesgos reales:** Simular el comportamiento de un atacante para descubrir las vulnerabilidades presentes en la aplicación web, la base de datos y la gestión de usuarios, determinando el nivel de riesgo real para el negocio.
2. **Evaluar los controles de acceso:** Comprobar la efectividad de los mecanismos de autenticación y la correcta segregación de privilegios entre los diferentes tipos de usuarios de la plataforma.
3. **Generar inteligencia procesable:** Documentar cada hallazgo técnico de manera clara y útil, para que el equipo de desarrollo de Aurora Market pueda tomar mejores decisiones de seguridad y aplicar correcciones oportunas.

2. ALCANCE

➤ SÍ SE EVALUARÁ:

- La aplicación web principal de Aurora Market.
- La base de datos subyacente vinculada a la aplicación.
- Los mecanismos de autenticación y los diferentes perfiles/roles de usuarios.

➤ FUERA DEL ALCANCE:

- Ataques de Denegación de Servicio (DoS/DDoS) que puedan afectar la disponibilidad.
- Ingeniería social contra empleados o clientes de Aurora Market.
- Infraestructura física, redes internas no expuestas y servicios de terceros.

3. AUTORIZACIÓN Y CONDICIONES

➤ PERMISOS REQUERIDOS:

- Firma de un documento de Reglas de Compromiso (Rules of Engagement / RoE) y un Acuerdo de Confidencialidad (NDA) aprobados por la directiva de Aurora Market.
- Provisión de cuentas de prueba representativas para los diferentes tipos de usuarios.

➤ CONDICIONES ACORDADAS:

- El equipo auditor asume el escenario con información técnica limitada (solo componentes básicos conocidos).
- Las pruebas ofensivas no deben comprometer la integridad de los datos reales de los clientes ni interrumpir las operaciones del e-commerce.
- Todo vector de ataque debe detenerse antes de causar daño colateral y reportarse de inmediato si es crítico.

4. TIPO DE PENTEST

- **Selección:** Caja Gris (Gray-Box).
- **Justificación:** El escenario indica que la empresa no entrega toda la información técnica (como código fuente o arquitectura de red profunda), lo que descarta Caja Blanca. Sin embargo, el equipo sí conoce la existencia de componentes específicos (aplicación web, base de datos) y la necesidad de evaluar "mecanismos de autenticación y diferentes tipos de usuarios". Para probar adecuadamente los roles y escalamiento de privilegios entre estos distintos usuarios, el equipo requiere credenciales de prueba, lo que posiciona el ejercicio como un enfoque de Caja Gris (simulando un atacante que ya ha obtenido cierto nivel de acceso o un cliente legítimo malintencionado).

5. PLANIFICACIÓN

- **Objetivos:** Evaluar la postura de seguridad de la infraestructura expuesta de Aurora Market y documentar hallazgos de forma clara para el equipo de desarrollo.
- **Alcance:** Aplicación web, base de datos y control de accesos.
- **Permisos y condiciones:** RoE firmado, evaluación sin interrupción del servicio.
- **Metodología a utilizar:** PTES (Penetration Testing Execution Standard) complementado con OWASP WSTG para la capa web.
- **Recopilación de información previa:** Mapeo de la superficie de ataque e identificación de tecnologías (frameworks, tipo de base de datos) que la empresa omitió entregar.
- **Recursos necesarios:** Herramientas de análisis de vulnerabilidades web (ej. Burp Suite), entorno de pruebas seguro y cuentas con diferentes perfiles de usuario.
- **Programación del pentest:** Definición de la ventana de pruebas (días y horarios autorizados) y fecha límite para la entrega del reporte detallado.

6. FASES DEL PENTEST

1. **Reconocimiento:** Como Aurora Market no detalló cómo está construida la plataforma, esta fase se centrará en descubrir las tecnologías web empleadas, la topología expuesta y los puntos de entrada (formularios, APIs, paneles de login).
2. **Análisis de vulnerabilidades:** Se escanearán y analizarán de forma manual y automatizada las entradas de datos, la gestión de sesiones y los mecanismos de autenticación para detectar configuraciones inseguras, fallas lógicas o vulnerabilidades conocidas en la tecnología descubierta.
3. **Explotación:** Se intentará aprovechar activamente las brechas detectadas (por ejemplo, intentar una inyección SQL en la base de datos o saltarse el control de acceso) para comprobar qué información real podría descubrir un atacante.

4. **Post-explotación:** Se medirá el impacto del compromiso. Si se vulnera un usuario de bajo perfil, se intentará escalar privilegios a un rol administrativo para demostrar el riesgo sobre los datos sensibles del negocio.
5. **Informe:** Se consolidará todo el ejercicio en un reporte estructurado que documente cuidadosamente los problemas encontrados, las evidencias (pruebas de concepto) y las recomendaciones específicas de mitigación para el equipo de desarrollo.

7. INVESTIGACIÓN

- **Metodología elegida:** PTES (Penetration Testing Execution Standard).
- **¿Por qué sería útil para este proyecto?:** PTES proporciona un marco de trabajo altamente estructurado que cubre desde las interacciones iniciales con el cliente hasta la entrega del informe. Para Aurora Market, que tiene como requisito principal que la información entregada sea "clara, útil y cuidadosamente documentada", la fase de "Reporte" de PTES garantiza que los hallazgos se clasifiquen según su riesgo real para el negocio y ofrezcan soluciones técnicas precisas para su equipo de desarrollo. Además, su fase de "Modelado de Amenazas" es ideal para abordar el requerimiento de probar los "diferentes tipos de usuarios" y sus flujos de datos.